fortbridge/cve-2026-108097-research: docs/SYNTHETIC-HTTP-WITNESS.md

fortbridge/cve-2026-108097-research: docs/SYNTHETIC-HTTP-WITNESS.md - Author not stated, GitHub.

- Published: date not stated
- Original: <https://github.com/fortbridge/cve-2026-108097-research/blob/1b8509713064e440068b0561eaf4a2a458831b2b/docs/SYNTHETIC-HTTP-WITNESS.md>
- Preserved from: https://github.com/fortbridge/cve-2026-108097-research/blob/1b8509713064e440068b0561eaf4a2a458831b2b/docs/SYNTHETIC-HTTP-WITNESS.md (github-api) on 2026-10-21
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so it remains readable if the page goes offline. To read the original, follow the link above.

Content

> UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

> **Repository reading copy.** Created from SYNTHETIC-HTTP-WITNESS.md.

SYNTHETIC-HTTP-WITNESS.md

`fortbridge/cve-2026-108097-research` at `1b8509713064`, path `docs/SYNTHETIC-HTTP-WITNESS.md`.

Synthetic HTTP witness on real Drupal, NOT the published contributed-module exploit

15 October 2026 BST. This is a conditional, owner-controlled demonstration only. The real Drupal 11.4.9 and 11.4.10 Docker applications serve normal HTTP traffic, with identical `lab_bridge` module code installed at `/opt/drupal/web/modules/custom/lab_bridge`. That module is OUR test fixture: it deliberately maps a query choice to one of two harmless PHP callbacks and constructs a `field_ui_table` row. It is not a discovered vulnerable contributed module or evidence that a stock site exposes this route. Host ports are bound to 127.0.0.1 only.

`lab_bridge` unauthenticated route `/lab-field-ui-probe?choice=mark` assigns `LabBridgeMarker::mark` to `#region_callback`; the marker only increments the private Drupal State integer `lab_bridge.marker_count` and returns region `content`. `choice=region` selects

a pure callback; other values also fall back to it. There is no shell, file write, exfiltration or arbitrary callable selection. The request passes through the real Drupal router, form element registration and renderer to the unmodified core `FieldUiTable::tablePreRender` on each build. A local Drush readback (not the HTTP response alone) observes the counter.

Run twice from `docker-lab`:

python synthetic_http_witness.py

Parent execution (two independent runs):

vulnerable unauth_http=200 control=0 marker=1 invalid_choice_no_change=True PASS
patched unauth_http=200 control=0 marker=0 invalid_choice_no_change=True PASS

The first script iteration failed because Drupal's page cache for unauthenticated users replayed a prior `choice=mark` response after the State counter was reset: HTTP 200 alone did not invoke the renderer. The corrected script adds a unique nonce to each local request and the vulnerable miss incremented the counter while the patched miss did not. Preserve the failed first iteration as a harness failure, not a target-negative. `core_form_negative.py` separately shows ordinary admin form input with an extra `#region_callback` POST key saves normally in both builds; unauthenticated access to that admin form is 403.

Supported: If an integration hands an HTTP-selected benign callable to a Field UI row, the affected core invokes it during a real request and the patched core does not. This is an actual Docker app/HTTP/effect/control execution of that synthetic conditional path.

NOT supported: A real-world contributed module doing this, an unauthenticated exploit path in default Drupal, arbitrary OS command execution, or an exploit of CVE-2026-108097 through the undisclosed route described by Drupal's advisory. The test bridge itself creates the missing trust-boundary crossing. Do not call this the final exploit requested in KAN-3005; KAN-3011 stays open until a genuine source-backed integration is found and exercised, or the work is explicitly stopped with an unproven result.

Archived from https://github.com/fortbridge/cve-2026-108097-research/blob/1b8509713064e440068b0561eaf4a2a458831b2b/docs/SYNTHETIC-HTTP-WITNESS.md. Rendered offline from the local Markdown copy.